

Guía de Estudio: Gestión de Riesgos

Guía organizada y desarrollada a partir de tus apuntes. Orden de estudio sugerido:
fundamentos → proceso → análisis → tratamiento → controles → metodologías/marcos → herramientas visuales → actividad práctica.

Índice

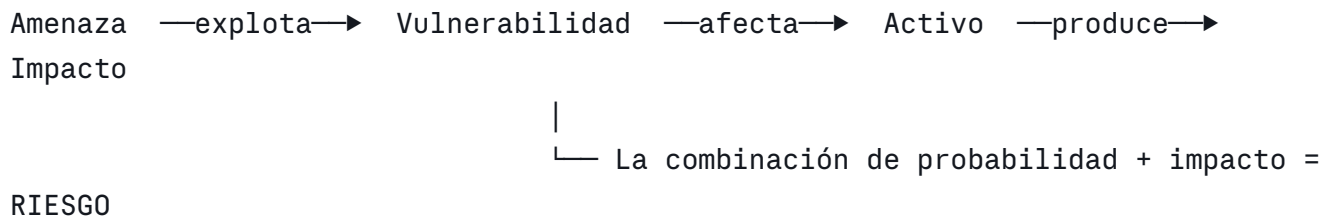
1. Conceptos fundamentales
 2. Gestión de riesgos: definición y utilidad
 3. Etapas de la metodología de gestión de riesgos
 4. Análisis de riesgos: cualitativo vs. cuantitativo
 5. Estrategias de tratamiento del riesgo
 6. Riesgo residual
 7. Tipos de controles
 8. Marcos y metodologías
 9. Herramientas visuales
 10. Actividad práctica (con ejemplo resuelto)
 11. Resumen y tabla comparativa
 12. Preguntas de repaso
-

1. Conceptos fundamentales

Antes de hablar de metodologías hay que dominar el vocabulario base. Estos cinco conceptos se relacionan entre sí:

Concepto	Definición	Ejemplos
Activo	Todo recurso valioso para la organización (información, sistemas, personas, infraestructura, reputación).	Base de datos de clientes, servidor, empleados clave, sitio web
Amenaza	Cualquier cosa que pueda causar daño a un activo.	Hackers, malware, errores humanos, incendios, fallas eléctricas
Vulnerabilidad	Debilidad que puede ser explotada por una amenaza.	Software sin parches, contraseñas débiles, falta de capacitación
Riesgo	Probabilidad de que una amenaza explote una vulnerabilidad y genere un impacto sobre un activo.	Que un ransomware cifre el servidor por no tener parches
Riesgo residual	Riesgo que permanece después de aplicar controles.	Riesgo restante tras instalar antivirus y respaldos

Relación entre los conceptos



Fórmula conceptual:

Riesgo = Amenaza × Vulnerabilidad × Impacto (o, más simple: Riesgo = Probabilidad × Impacto)

Tip de estudio: una amenaza sin vulnerabilidad no genera riesgo, y una vulnerabilidad sin amenaza que la explote tampoco. El riesgo existe cuando ambas coinciden sobre un activo con valor.

2. Gestión de riesgos: definición y utilidad

Definición: proceso sistemático para **identificar, evaluar, tratar y monitorear** los riesgos que pueden afectar a una organización o a un proyecto.

¿Para qué sirve? (Ideas clave)

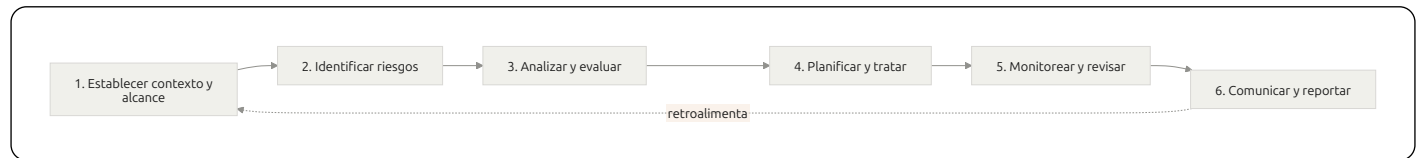
1. **Priorizar riesgos críticos.** No se puede mitigar todo; se atiende primero lo que más daño

puede causar.

2. **Justificar presupuesto.** Permite demostrar con datos por qué se invierte en ciertos controles (especialmente con análisis cuantitativo).
3. **Cumplir con normativas.** Muchas leyes y estándares (ISO 27001, regulaciones de protección de datos, etc.) exigen demostrar una gestión de riesgos formal.

3. Etapas de la metodología de gestión de riesgos

Es un **ciclo continuo**, no un proceso de una sola vez.



Etapa 1. Establecer el contexto y alcance

Definir **qué se va a proteger y bajo qué condiciones**: activos, perímetro, contexto interno y externo de la empresa, objetivos del negocio, criterios de aceptación del riesgo.

- *Pregunta guía*: ¿Qué analizo y hasta dónde llega el análisis?

Etapa 2. Identificar riesgos

Determinar y comprender los **eventos potenciales** que pueden impactar los objetivos o activos.

- Técnicas comunes: lluvia de ideas, entrevistas, listas de verificación, revisión de incidentes pasados, análisis de amenazas y vulnerabilidades.
- *Pregunta guía*: ¿Qué puede salir mal, cómo y por qué?

Etapa 3. Analizar y evaluar riesgos

- **Analizar**: estimar probabilidad e impacto (de forma **cualitativa** o **cuantitativa**, ver sección 4).
- **Evaluar**: comparar el nivel de riesgo contra los criterios de aceptación para decidir cuáles requieren tratamiento y en qué orden.

Etapa 4. Planificar y tratar riesgos

Diseñar **planes de respuesta** para los riesgos identificados. Las cuatro opciones son: **evitar, reducir (mitigar), transferir o aceptar** (ver sección 5).

Etapa 5. Monitorear y revisar

Supervisar de forma **continua** los riesgos y la **efectividad de los controles** implementados, para asegurar que se mantengan **actualizados y relevantes** (el entorno cambia: nuevas amenazas, nuevos activos, cambios tecnológicos).

Etapa 6. Comunicar y generar reportes/informes

Mantener informadas a las **partes interesadas** (dirección, usuarios, áreas responsables) sobre los riesgos y su gestión. Incluye el **reporte de prevención**. La comunicación ocurre **durante**

todo el ciclo, no solo al final.

Versión alternativa del ciclo (en 5 pasos, enfoque más técnico)

Paso	Actividad
1	Identificación de activos
2	Análisis de amenazas y vulnerabilidades
3	Evaluación del impacto y la probabilidad
4	Tratamiento del riesgo (aceptar, mitigar, transferir, evitar)
5	Monitoreo y revisión

4. Análisis de riesgos: cualitativo vs. cuantitativo

4.1 Análisis cualitativo

Trabaja con **variables abstractas, menos tangibles y/o subjetivas**. Usa escalas descriptivas (bajo/medio/alto) o numéricas simples (1 a 5).

Ejemplos de variables cualitativas:

- Pérdida de convenios
- Afectación de la reputación
- Pérdida de confianza de los clientes
- Disminución del compromiso de los trabajadores

Ventajas	Desventajas
Rápido y barato	Subjetivo (depende del criterio de quien evalúa)
No requiere datos históricos	Difícil de comparar entre áreas
Fácil de comunicar (matrices, mapas de calor)	No justifica presupuesto con cifras

4.2 Análisis cuantitativo

Trabaja con **variables tangibles y precisas**. Asigna **valores monetarios concretos** a los componentes del riesgo para obtener una visión financiera. Es ideal para **justificar el costo de los controles**, aunque requiere datos históricos o estimados precisos.

Ejemplos de variables cuantitativas:

- Pérdidas monetarias
- Disminución en la tasa de altas de clientes
- Tiempo fuera de servicio (downtime)

Fórmulas clave

Sigla	Nombre	Fórmula
AV	Valor del activo (<i>Asset Value</i>)	Dato de entrada
EF	Factor de exposición (<i>Exposure Factor</i>)	% del activo que se pierde si ocurre el evento (0 a 1)
SLE	Expectativa de pérdida singular (<i>Single Loss Expectancy</i>)	$SLE = AV \times EF$
ARO	Tasa anual de ocurrencia (<i>Annualized Rate of Occurrence</i>)	Veces por año que se espera el evento
ALE	Pérdida anual esperada (<i>Annual Loss Expectancy</i>)	$ALE = SLE \times ARO$

Ejemplo resuelto

Un servidor vale **\$200,000 MXN**. Si sufre un ataque de ransomware se pierde el **40 %** de su valor/operación. Se estima que ocurre **1 vez cada 2 años** (ARO = 0.5).

$$SLE = 200,000 \times 0.40 = \$80,000$$
$$ALE = 80,000 \times 0.5 = \$40,000 \text{ por año}$$

Uso para decidir: si un control cuesta **\$15,000 al año** y reduce el ALE a **\$10,000**, el beneficio es $40,000 - 10,000 = 30,000 > 15,000 \rightarrow$ **el control se justifica.**

$$\begin{aligned} \text{Valor del control} &= \text{ALE antes} - \text{ALE después} - \text{Costo anual del control} \\ &= 40,000 - 10,000 - 15,000 = \$15,000 \text{ (positivo} \rightarrow \text{ conviene)} \end{aligned}$$

4.3 Comparativa rápida

Criterio	Cualitativo	Cuantitativo
Variables	Abstractas, subjetivas	Tangibles, medibles
Resultado	Niveles (bajo, medio, alto)	Cifras monetarias
Datos necesarios	Pocos	Históricos o estimados precisos
Costo y tiempo	Bajo	Alto
Mejor para	Priorización inicial, comunicación	Justificar inversión

En la práctica se suelen **combinar**: primero cualitativo para filtrar, luego cuantitativo para los riesgos críticos.

5. Estrategias de tratamiento del riesgo

Una vez evaluado el riesgo se decide qué hacer con él:

Estrategia	Qué significa	Ejemplo
Evitar	Eliminar la actividad que genera el riesgo.	No usar memorias USB desconocidas; no almacenar datos sensibles que no se necesitan
Mitigar (reducir)	Disminuir la probabilidad y/o el impacto.	Instalar antivirus, aplicar parches, hacer respaldos
Transferir	Pasar el riesgo (o su impacto financiero) a un tercero.	Contratar un seguro, subcontratar el servicio
Aceptar	Asumir el riesgo porque es bajo o porque el costo de mitigarlo es muy alto.	Aceptar la falla de un equipo no crítico

Las cinco estrategias clásicas de mitigación (versión desglosada)

Algunos textos separan "reducir" en dos:

1. **Evitar**
2. **Reducir probabilidad** (controles preventivos: que el evento ocurra menos)
3. **Reducir impacto** (controles correctivos/de recuperación: que, si ocurre, duela menos)
4. **Transferir**
5. **Aceptar**

Importante: transferir un riesgo **no lo elimina**; solo cambia quién absorbe la pérdida económica. La responsabilidad legal o reputacional puede seguir siendo tuya.

¿Cómo elegir?

¿El riesgo es inaceptable y la actividad no es esencial?	→ EVITAR
¿Se puede reducir a un costo razonable?	→ MITIGAR
¿Es costoso de mitigar pero el impacto es financiero?	→ TRANSFERIR
¿Es bajo o mitigarlo cuesta más que el daño?	→ ACEPTAR

6. Riesgo residual

Definición: nivel de riesgo que **persiste o permanece después de haber aplicado los controles de seguridad**.

Riesgo inherente (sin controles) —(aplicar controles)—> Riesgo residual (con controles)

- Ningún control elimina el riesgo al 100 %, por eso siempre queda un residual.
- El riesgo residual debe estar **dentro del apetito/tolerancia de riesgo** de la organización; si no, se requieren más controles.
- Es la base para **mostrar cómo cambia el riesgo antes y después** (ver actividad práctica).

7. Tipos de controles

Los controles son las medidas que reducen el riesgo. Se clasifican de dos maneras que se combinan entre sí.

7.1 Por naturaleza (¿qué tipo de medida es?)

Tipo	Descripción	Ejemplos
Administrativos	Políticas, procedimientos y gestión de personas.	Políticas de seguridad, capacitación, contratos, segregación de funciones
Técnicos (lógicos)	Tecnología que protege sistemas y datos.	Firewall, antivirus, cifrado, autenticación multifactor (MFA)
Físicos	Protección del entorno material.	Cerraduras, cámaras, guardias, control de acceso a sitios, extintores

7.2 Por función (¿en qué momento actúan?)

Función	Objetivo	Ejemplos
Preventivos	Evitar que el evento ocurra.	Control de acceso, parches, capacitación anti-phishing
Detectivos	Identificar que el evento está ocurriendo o ocurrió.	IDS/SIEM, alarmas, auditorías, cámaras de monitoreo
Correctivos	Reducir el daño y restaurar después del evento.	Respaldos, plan de recuperación ante desastres, restauración
Disuasorios	Desalentar a un posible atacante.	Letreros de advertencia, avisos legales, cámaras visibles

7.3 Matriz de ejemplos (naturaleza × función)

	Preventivo	Detectivo	Correctivo	Disuasorio
Administrativo	Política de contraseñas	Auditorías internas	Plan de continuidad	Sanciones disciplinarias
Técnico	Firewall, MFA	SIEM, IDS	Restauración desde backup	Banner de aviso legal
Físico	Cerraduras, tarjetas de acceso	Cámaras, sensores	Extintor, generador de respaldo	Letrero "Zona vigilada"

Los controles de **recuperación** (los que pide la actividad) son **correctivos**.

8. Marcos y metodologías

Son los "mapas" estandarizados que guían cómo gestionar el riesgo. Ninguno es mejor en todos los casos; se elige según el contexto (país, industria, enfoque técnico o de negocio).

8.1 Norma ISO 31000

Qué es: norma internacional que proporciona **directrices generales** para la gestión de riesgos, aplicable a cualquier organización, sector o tipo de riesgo (no es exclusiva de TI). Destaca el **establecimiento del contexto, la evaluación, el tratamiento y el seguimiento**.

Pasos según tus apuntes:

1. Establecer contexto
2. Contar con un responsable de gestión de riesgos
3. Identificar riesgos
4. Categorizar riesgos
5. Comunicar resultados
6. Validar el sistema de riesgos
7. Definir la respuesta a cada riesgo
8. Crear un plan de acción
9. Hacer seguimiento

Nota: en el texto oficial de la norma, el proceso se organiza en: *comunicación y consulta; alcance, contexto y criterios; evaluación del riesgo (identificación, análisis, valoración); tratamiento; seguimiento y revisión; registro e informe*. La lista de 9 pasos es una forma didáctica de bajarlo a la práctica. Revisa cuál versión pide tu profesor.

8.2 Marco COSO

Qué es: el Comité de Organizaciones Patrocinadoras de la Comisión Treadway (COSO) creó un modelo de **gestión de riesgos y control interno** que integra ambos procesos para dar una **visión más completa de la postura de riesgo** de la organización. Es muy usado en auditoría y finanzas.

Componentes (control interno):

Componente	Idea central
Ambiente de control	Cultura, ética, estructura y compromiso de la dirección; es la base de todo
Evaluación de riesgos	Identificar y analizar riesgos que amenazan los objetivos
Actividades de control	Políticas y procedimientos que aseguran que se ejecuten las respuestas al riesgo
Información y comunicación	Datos relevantes fluyendo en tiempo y forma hacia quien los necesita
Monitoreo	Evaluaciones continuas o periódicas para verificar que el control funciona

8.3 NIST SP 800-30

Qué es: guía del Instituto Nacional de Estándares y Tecnología (NIST) de EE. UU. para realizar **evaluaciones de riesgo** de seguridad de la información, con el fin de **proteger activos y prevenir riesgos**.

- Es de enfoque **técnico y muy práctico**, paso a paso.
- Es la guía base dentro del conjunto de documentos NIST (se relaciona con NIST SP 800-37 y el Marco de Ciberseguridad NIST).
- Su proceso general: **preparar la evaluación → realizarla → comunicar resultados → mantenerla actualizada**.

8.4 OCTAVE

Nombre completo: *Operationally Critical Threat, Asset, and Vulnerability Evaluation* (Evaluación de Amenazas, Activos y Vulnerabilidades Operacionalmente Críticas).

Enfoque: alinear las prácticas de seguridad con los objetivos de negocio.

- Identifica **amenazas**.
- Prioriza **activos**.
- Analiza **vulnerabilidades**.
- Es una metodología **autodirigida**: la propia organización (personal de negocio y de TI) hace la evaluación, no depende de consultores externos.

8.5 MAGERIT

Qué es: metodología formal desarrollada en **España** para el **análisis y la gestión de riesgos en sistemas de información** (de la administración pública, aunque se usa ampliamente).

Objetivos:

- Identificar los riesgos a los que están expuestos los sistemas, **analizando amenazas y**

vulnerabilidades.

- Establecer **medidas preventivas** para mitigarlos.

■ **Para recordar:** MAGERIT = España + sistemas de información.

8.6 FAIR

Nombre completo: *Factor Analysis of Information Risk*.

Qué es: marco estandarizado y cuantitativo para:

- Evaluar y gestionar **riesgos cibernéticos y operativos**.
- **Cuantificar la probabilidad y el impacto financiero** de las amenazas, ayudando a los responsables a **tomar decisiones informadas sobre ciberseguridad**.

Estructura: se desglosa en el análisis de **frecuencia** y **magnitud**, dividiendo estos factores en componentes más pequeños:

RIESGO (en dinero)

├ Frecuencia de eventos de pérdida (¿cuántas veces?)

| └ Frecuencia de contacto/amenaza

| └ Vulnerabilidad (probabilidad de que la amenaza tenga éxito)

└ Magnitud de la pérdida (¿cuánto cuesta cada vez?)

├ Pérdidas primarias (respuesta, reposición, productividad)

└ Pérdidas secundarias (multas, daño a la reputación)

8.7 Comparativa de marcos

Marco	Origen	Enfoque	Tipo de análisis	Idea clave
ISO 31000	Internacional (ISO)	General, cualquier tipo de riesgo	Flexible	Directrices y principios
COSO	EE. UU. (Comité Treadway)	Control interno y riesgo empresarial	Cualitativo/ mixto	Integra riesgo y control
NIST SP 800-30	EE. UU. (NIST)	Seguridad de la información	Cualitativo/ cuantitativo	Guía técnica paso a paso
OCTAVE	Carnegie Mellon (SEI)	Seguridad alineada al negocio	Cualitativo	Autoevaluación de activos críticos
MAGERIT	España	Sistemas de información	Cualitativo/ cuantitativo	Metodología formal pública
FAIR	Estándar abierto	Ciberriesgo	Cuantitativo	Riesgo expresado en dinero

9. Herramientas visuales

9.1 Matriz de probabilidad e impacto

Herramienta **cualitativa** para ubicar y priorizar riesgos. Cada riesgo se coloca según su **probabilidad** (eje vertical) y su **impacto** (eje horizontal). El nivel de riesgo es $\text{Probabilidad} \times \text{Impacto}$.

Matriz 5×5 (valores = P × I):

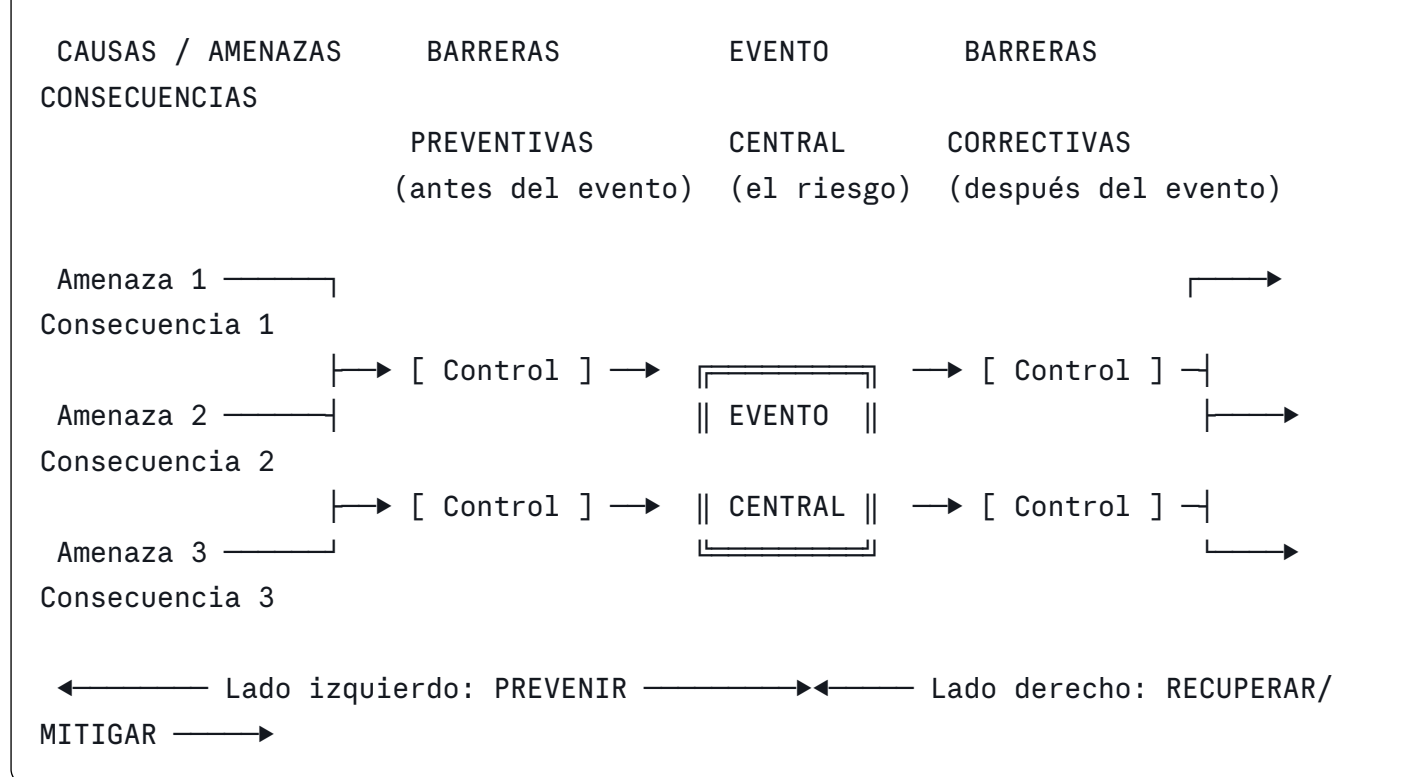
Probabilidad ↓ / Impacto →	1 Insignificante	2 Menor	3 Moderado	4 Mayor	5 Catastrófico
5 Casi seguro	 5	 10	 15	 20	 25
4 Probable	 4	 8	 12	 16	 20
3 Posible	 3	 6	 9	 12	 15
2 Poco probable	 2	 4	 6	 8	 10
1 Raro	 1	 2	 3	 4	 5

Interpretación de colores:

Color	Rango	Nivel	Acción típica
	1-4	Bajo	Aceptar y monitorear
	5-8	Medio	Monitorear, mitigar si es barato
	9-12	Alto	Plan de tratamiento planificado
	15-25	Crítico	Acción inmediata, prioridad máxima

9.2 Diagrama Bow-Tie (corbatín)

Muestra **amenazas, evento central, consecuencias y controles en un solo golpe de vista**. Se llama así porque su forma recuerda a un moño o corbatín.



Partes del diagrama:

Parte	Descripción
Evento central (nudo)	El momento en que se pierde el control; el riesgo materializado
Amenazas/causas (izquierda)	Qué puede originar el evento
Controles preventivos (izquierda)	Barreras que impiden que la causa llegue al evento
Consecuencias (derecha)	Daños si el evento ocurre
Controles correctivos/de recuperación (derecha)	Barreras que reducen el daño después del evento

Regla mnemotécnica: izquierda = *prevención*, derecha = *recuperación*. Es el diagrama que conecta directamente con los tipos de control por función (sección 7.2).

10. Actividad práctica (con ejemplo resuelto)

10.1 Instrucciones de la actividad

- Elegir.** Seleccionar un riesgo real de su entorno universitario o empresa (en ese caso, poner el contexto).
- Ubicar.** Proponer su posición en una matriz de probabilidad e impacto.
- Mitigar.** Proponer **2 controles preventivos** y **1 de recuperación**.
- Comparar.** Mostrar cómo cambia el riesgo **antes y después**.

Entregable: debe incluir el **diagrama de matriz de probabilidad e impacto** y el **diagrama Bow-Tie**.

Datos de entrega (de tus apuntes): enviar por correo; nombre del archivo
22442_paternonombre_s6.

10.2 Ejemplo resuelto (úsalo como plantilla)

Paso 1. Contexto y riesgo elegido

Contexto: universidad con un servidor que aloja el sistema de calificaciones y expedientes de estudiantes. Se accede desde la red del campus y desde internet. El personal administrativo usa correo institucional y tiene poca capacitación en seguridad.

Riesgo: *Cifrado de la información académica por ransomware, con pérdida de disponibilidad del sistema de calificaciones.*

Elemento	Detalle
Activo	Servidor y base de datos de calificaciones/expedientes
Amenaza	Ransomware (típicamente llegado por phishing)
Vulnerabilidades	Sistemas sin parches, falta de MFA, usuarios sin capacitación, respaldos en la misma red
Impacto	Sistema caído días o semanas, pérdida de datos, afectación a la reputación, posibles sanciones por datos personales

Paso 2. Ubicación inicial en la matriz (riesgo inherente)

- **Probabilidad:** 4 (Probable). Los ataques de phishing/ransomware a instituciones educativas son frecuentes y hay vulnerabilidades abiertas.
- **Impacto:** 5 (Catastrófico). Se detendría la operación académica y se perderían datos.
- **Nivel de riesgo** = 4 × 5 = 20 →  **Crítico.**

Paso 3. Controles propuestos

#	Control	Tipo por función	Tipo por naturaleza	Qué reduce
1	Autenticación multifactor (MFA) + parcheo mensual de sistemas	Preventivo	Técnico	Probabilidad
2	Capacitación y simulacros anti-phishing para el personal	Preventivo	Administrativo	Probabilidad
3	Respaldos automáticos fuera de línea + plan de recuperación probado	Recuperación (correctivo)	Técnico/ Administrativo	Impacto

Paso 4. Ubicación final en la matriz (riesgo residual)

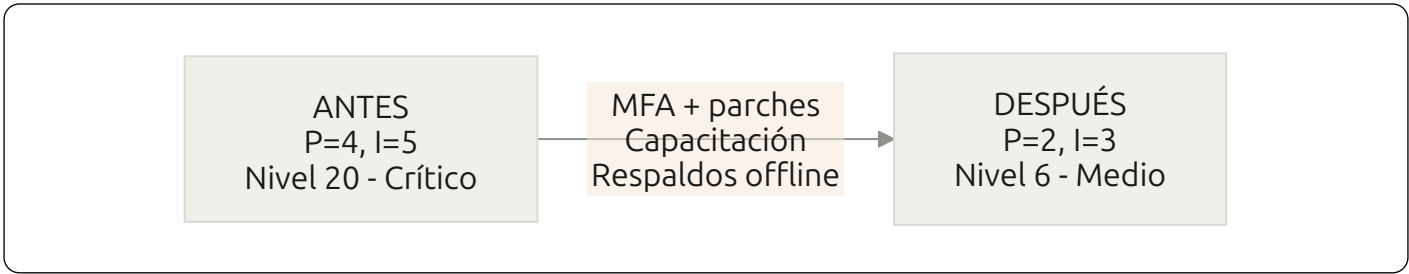
- **Probabilidad:** baja de 4 a 2 (Poco probable) gracias a los controles 1 y 2.
- **Impacto:** baja de 5 a 3 (Moderado) gracias al control 3 (la restauración reduce el tiempo caído y la pérdida de datos).
- **Nivel de riesgo** = $2 \times 3 = 6 \rightarrow$  **Medio.**

	Probabilidad	Impacto	Nivel	Clasificación
Antes (inherente)	4	5	20	 Crítico
Después (residual)	2	3	6	 Medio
Reducción	-2	-2	-14 (≈ 70 %)	

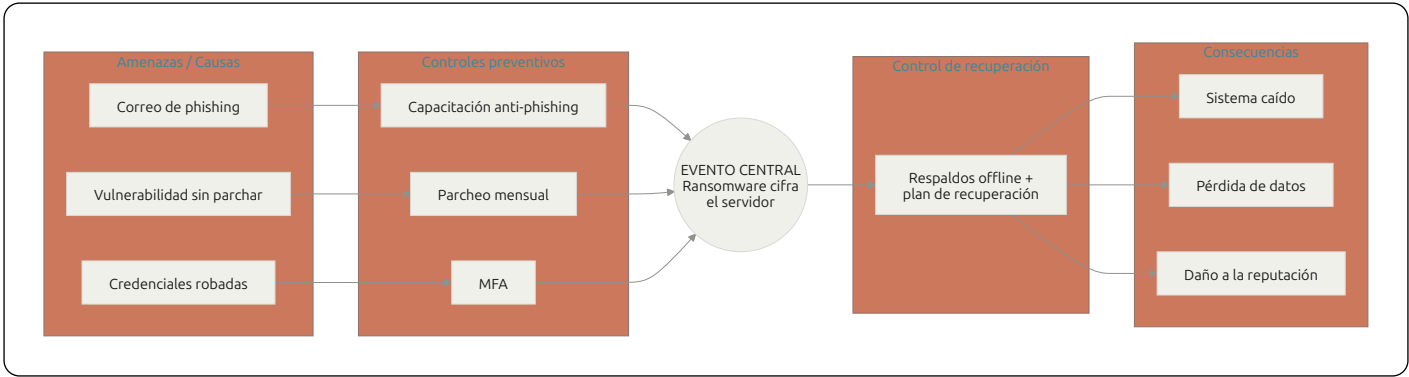
Paso 5. Matriz con el movimiento del riesgo

A = posición antes, D = posición después.

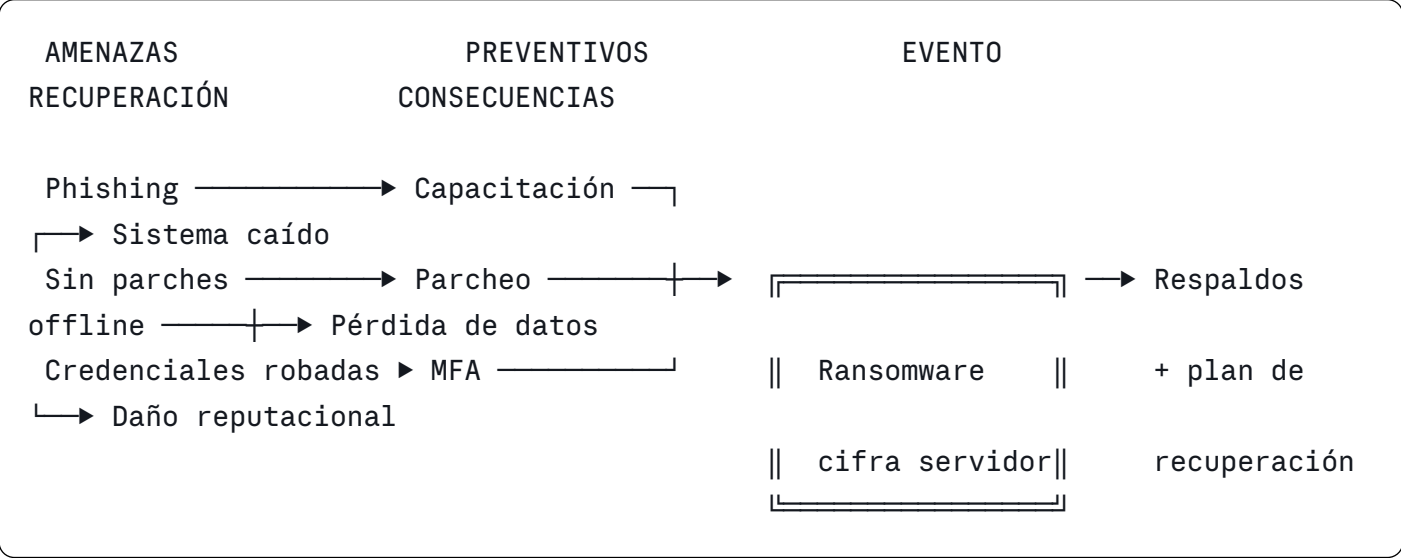
Prob. ↓ / Impacto →	1	2	3	4	5
5	5	10	15	20	25
4	4	8	12	16	A 20
3	3	6	9	12	15
2	2	4	D 6	8	10
1	1	2	3	4	5



Paso 6. Diagrama Bow-Tie del ejemplo



Versión en texto (para pegar en un documento):



10.3 Checklist antes de entregar

- ☐ Contexto descrito (universidad o empresa).
- ☐ Riesgo claro: activo + amenaza + vulnerabilidad + impacto.
- ☐ Matriz de probabilidad e impacto con la ubicación **antes y después**.
- ☐ **2 controles preventivos y 1 de recuperación**, bien identificados.
- ☐ Diagrama **Bow-Tie** completo (causas, preventivos, evento, recuperación, consecuencias).
- ☐ Justificación de por qué cambian la probabilidad y el impacto.
- ☐ Archivo nombrado (22442_paternonombre_s6) y enviado por correo.

11. Resumen y tabla comparativa

Mapa mental del tema



GESTIÓN DE RIESGOS

- |
- | — Conceptos: Activo · Amenaza · Vulnerabilidad · Riesgo · Riesgo residual
- |
- | — Proceso: Contexto → Identificar → Analizar/Evaluar → Tratar → Monitorear → Comunicar
- |
- | — Análisis
 - | — Cualitativo (subjetivo: reputación, confianza, convenios)
 - | — Cuantitativo ($SLE = AV \times EF$ · $ALE = SLE \times ARO$)
- |
- | — Tratamiento: Evitar · Mitigar · Transferir · Aceptar
- |
- | — Controles
 - | — Por naturaleza: Administrativos · Técnicos · Físicos
 - | — Por función: Preventivos · Detectivos · Correctivos · Disuasorios
- |
- | — Marcos: ISO 31000 · COSO · NIST SP 800-30 · OCTAVE · MAGERIT · FAIR
- |
- | — Herramientas: Matriz probabilidad × impacto · Diagrama Bow-Tie

Fórmulas esenciales

Riesgo (cualitativo) = Probabilidad × Impacto
 $SLE = \text{Valor del activo} \times \text{Factor de exposición}$
 $ALE = SLE \times ARO$

12. Preguntas de repaso

1. ¿Cuál es la diferencia entre amenaza y vulnerabilidad? Da un ejemplo de cada una.
2. ¿Por qué se dice que la gestión de riesgos es un ciclo y no un proceso lineal?
3. ¿Cuándo conviene usar un análisis cuantitativo en lugar de uno cualitativo?
4. Un activo vale \$500,000, el factor de exposición es 20 % y el ARO es 2. Calcula el SLE y el ALE. (Respuesta: $SLE = \$100,000$; $ALE = \$200,000$.)
5. Menciona las cuatro estrategias de tratamiento del riesgo y un ejemplo de cada una.
6. ¿Por qué transferir un riesgo no equivale a eliminarlo?
7. ¿Qué es el riesgo residual y por qué siempre existe?
8. Diferencia entre un control preventivo, uno detectivo y uno correctivo.
9. ¿Qué marco es cuantitativo y expresa el riesgo en términos financieros? ¿Cuál se originó en España?
10. ¿Qué representa el lado izquierdo y el derecho de un diagrama Bow-Tie?
11. ¿Qué componentes tiene el marco COSO?

12. ¿Qué enfoque distingue a OCTAVE de otras metodologías?

Fin de la guía. Sugerencia: estudia primero las secciones 1 a 7 (base teórica), luego compara los marcos (sección 8) y practica con la actividad (sección 10).